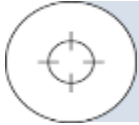


Atelier 3 : scénarios stratégiques



OBJECTIF : Identifier les parties prenantes critiques de l'écosystème, construire des scénarios de risque de haut niveau (scénarios stratégiques) et mesures de sécurité retenues pour l'écosystème

ÉLÉMENTS EN ENTRÉE :

- Missions et valeurs métier **(atelier 1)**
- Événements redoutés et leur gravité **(atelier 1)**
- Sources de risque et objectifs visés retenus **(atelier 2)**



ÉLÉMENTS EN SORTIE :

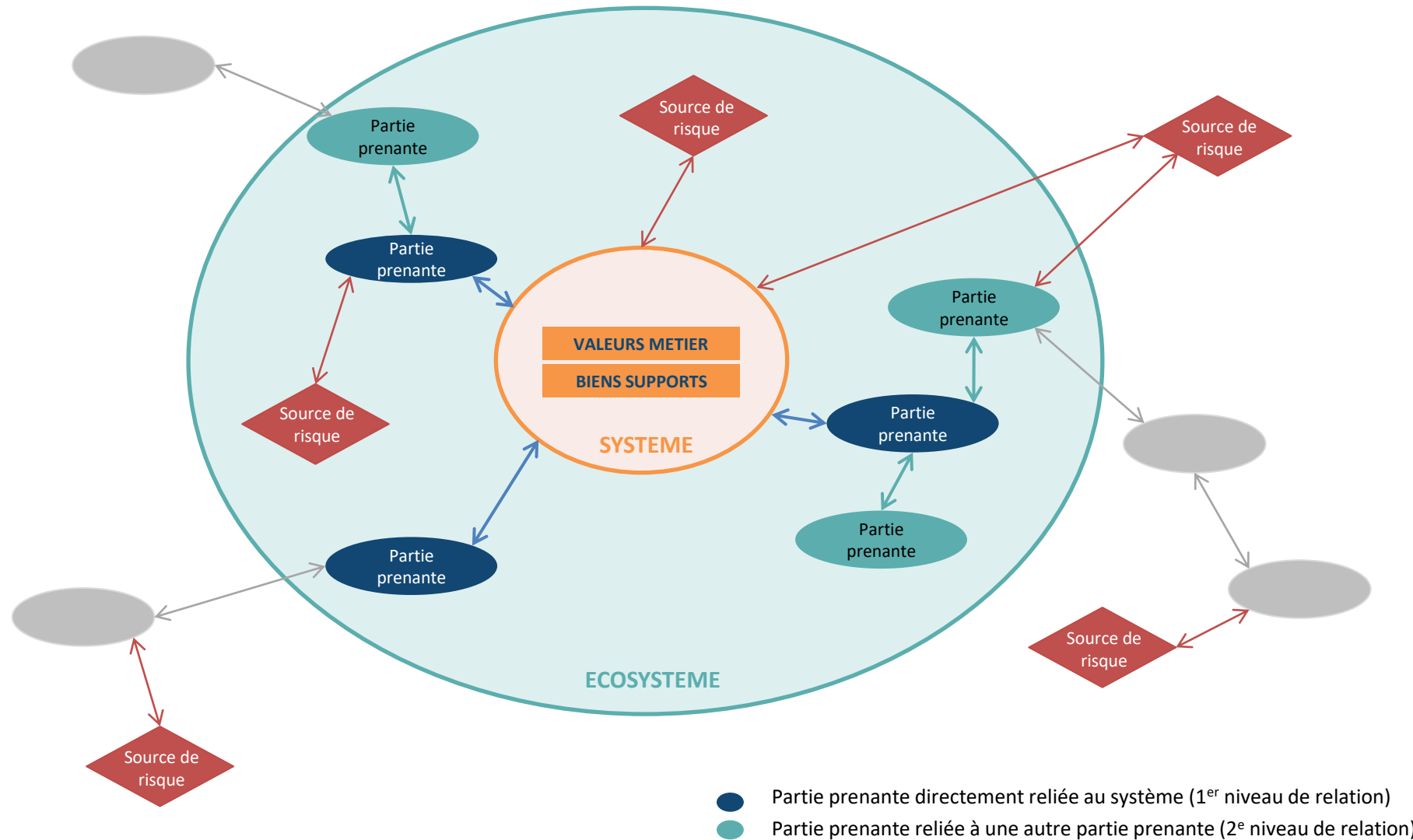
- Cartographie de menace de l'écosystème
- Scénarios stratégiques
- Mesures de sécurité retenues pour l'écosystème



PARTICIPANTS : Métiers, Architectes fonctionnels, Juristes, Acheteurs, RSSI, (Spécialiste cyber)

1. Construire la cartographie de menace de l'écosystème

Identifier les parties prenantes de l'écosystème

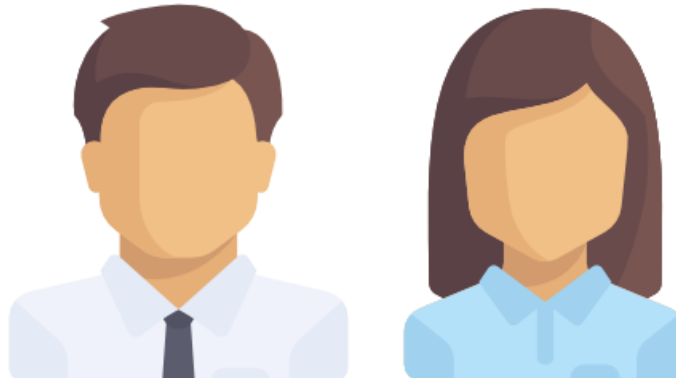


1. Construire la cartographie de menace de l'écosystème

Les questions à se poser

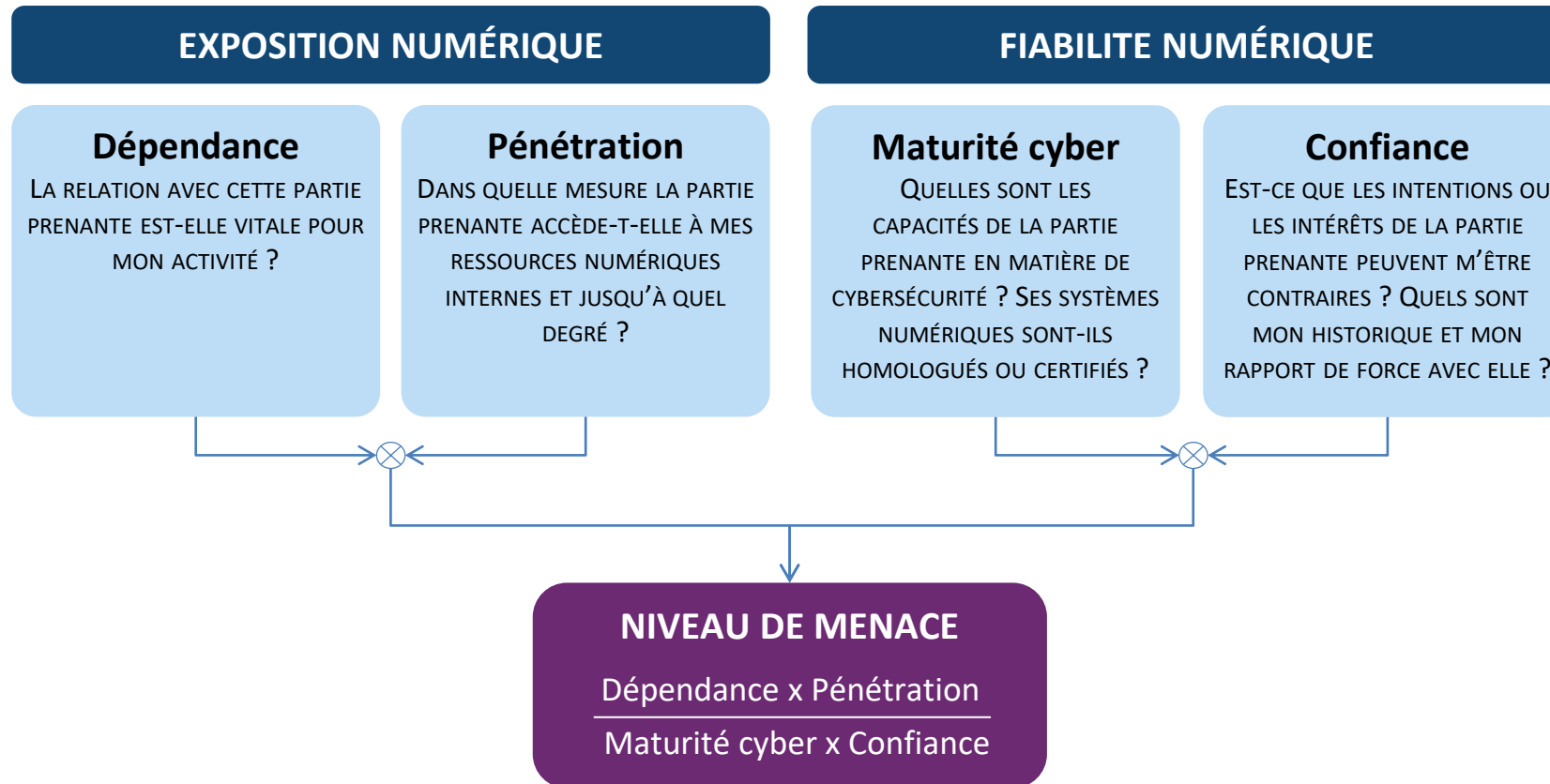
Quelles sont les **PARTIES PRENANTES** qui interviennent ou contribuent à la réalisation des missions et activités ?

Quelle **MENACE NUMÉRIQUE** fait peser chaque partie prenante sur les activités et services concernés ? Quelles sont les parties prenantes les **plus critiques** ?



1. Construire la cartographie de menace de l'écosystème

Comment évaluer le niveau de menace de chaque partie prenante ?



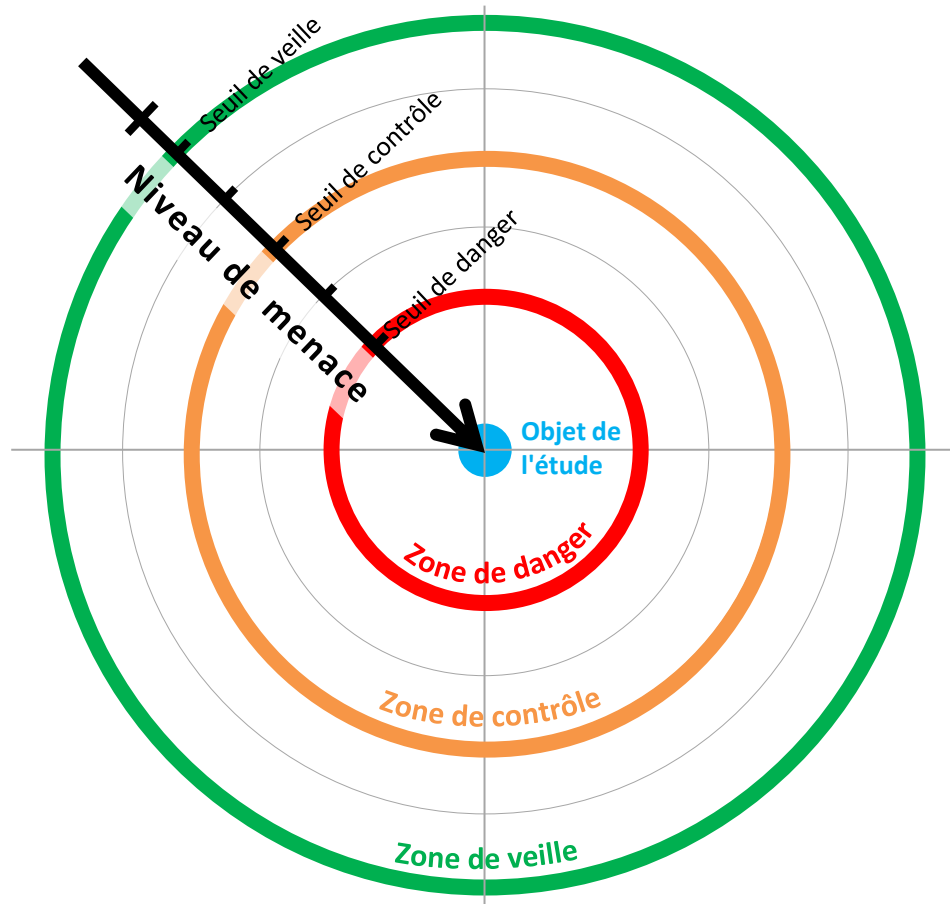
EBIOS RM – Atelier 3 : Scénarios stratégiques

a) Cartographie de menace de l'écosystème

DÉPENDANCE FONCTIONNELLE	PÉNÉTRATION	MATURITÉ SSI	CONFIANCE
1 : Relation non nécessaire aux fonctions stratégiques	1 : Pas d'accès ou accès avec privilèges de type utilisateur à des terminaux utilisateurs (poste de travail, ordiphone, etc.).	1 : Des règles d'hygiène sont appliquées ponctuellement et non formalisées. La capacité de réaction sur incident est incertaine.	1 : Les intentions de la partie prenante ne peuvent être évaluées.
2 : Relation utile aux fonctions stratégiques	2 : Accès avec privilèges de type administrateur à des terminaux utilisateurs (parc informatique, flotte de terminaux mobiles, etc.) ou accès physique aux sites de l'organisation.	2 : Les règles d'hygiène et la réglementation sont prises en compte, sans intégration dans une politique globale. La sécurité numérique est conduite selon un mode réactif.	2 : Les intentions de la partie prenante sont considérées comme neutres.
3 : Relation indispensable mais non exclusive	3 : Accès avec privilèges de type administrateur à des serveurs « métier » (serveur de fichiers, bases de données, serveur web, serveur d'application, etc.).	3 : Une politique globale est appliquée en matière de sécurité numérique. Celle-ci est assurée selon un mode réactif, avec une recherche de centralisation et d'anticipation sur certains risques.	3 : Les intentions de la partie prenante sont connues et probablement positives.
4 : Relation indispensable et unique (pas de substitution possible à court terme)	4 : Accès avec privilèges de type administrateur à des équipements d'infrastructure (annuaires , DNS, DHCP, commutateurs, pare-feu, hyperviseurs, baies de stockage, etc.) ou accès physique aux salles serveurs de l'organisation.	4 : La partie prenante met en œuvre une politique de management du risque. La politique est intégrée et prend pleinement en compte une dimension proactive.	4 : Les intentions de la partie prenante sont parfaitement connues et pleinement compatibles avec celles de l'organisation étudiée.

1. Construire la cartographie de menace de l'écosystème

Quel mode de représentation adopter pour ma cartographie ?



Zone de danger

Niveau de menace très élevé et inacceptable !

Zone de contrôle

Niveau de menace élevé mais tolérable sous contrôle

Zone de veille

Niveau de menace faible et acceptable en l'état

Les parties prenantes situées dans les zones de danger et de contrôle doivent être incluses dans le périmètre d'appréciation des risques car elles risquent d'être exploitées par un attaquant. Concrètement, ces parties prenantes (dites critiques) doivent être prises en compte dans l'élaboration des scénarios stratégiques.

➡ C'est dans l'atelier 3 que le périmètre de l'analyse de risque est véritablement défini. Ce périmètre inclut le système concerné mais également les parties prenantes internes et externes critiques de l'E/S

2. Élaborer des scénarios stratégiques

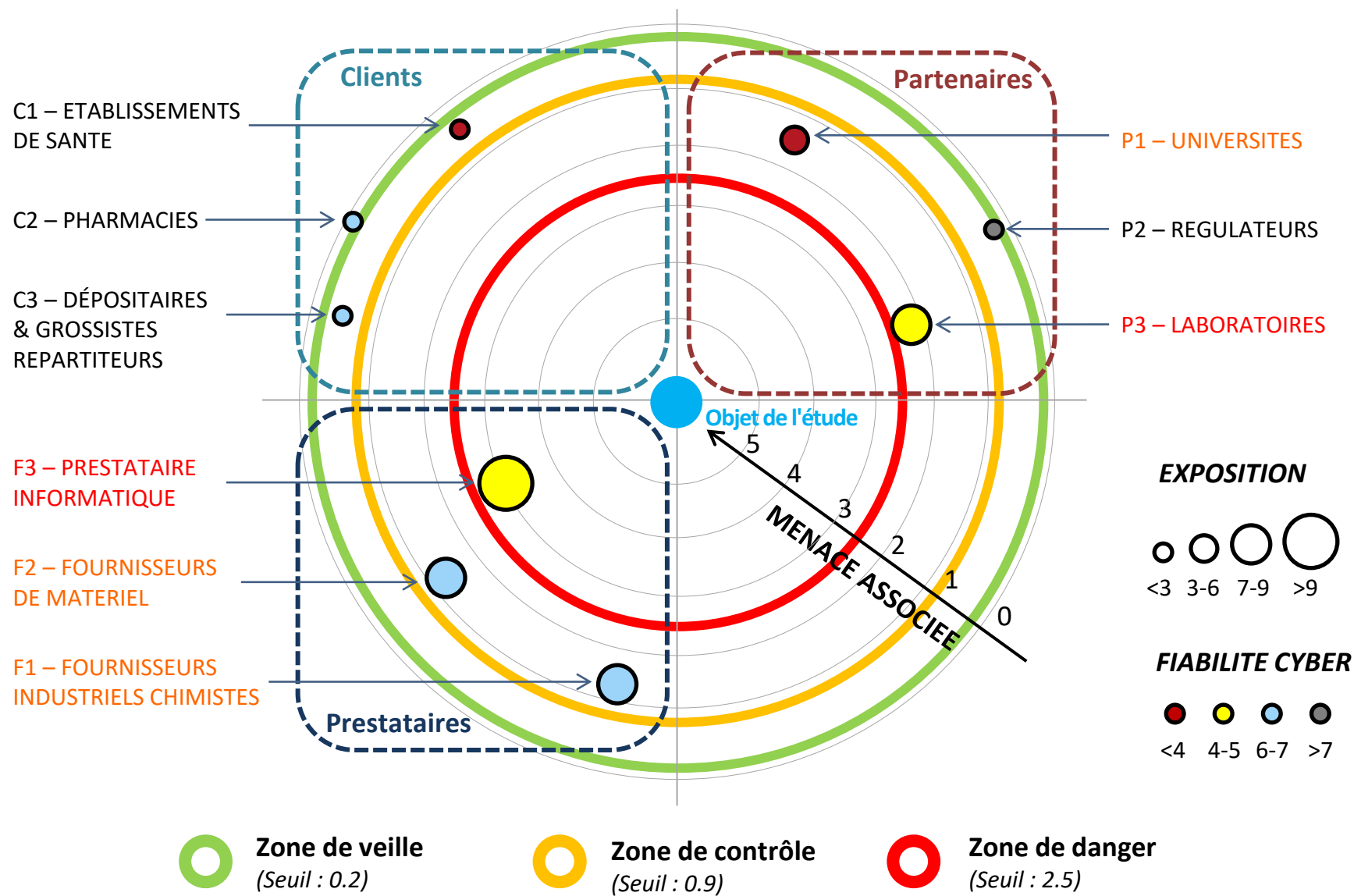
Exemple : société de biotechnologie

Catégorie	Partie prenante	Dépendance	Pénétration	Maturité	Confiance	Niveau de menace
Clients	C1 – Établissements de santé	1	1	1	3	0,3
	C2 – Pharmacies	1	1	2	3	0,2
	C3 – Dépositaires & Grossistes répartiteurs	1	2	2	3	0,3
Partenaires	P1 – Universités	2	2	1	3	1,3
	P2 – Régulateurs	2	1	2	4	0,25
	P3 – Laboratoires	3	3	2	2	2,25
Prestataires	F1 – Fournisseurs industriels chimistes	4	2	2	3	1,3
	F2 – Fournisseurs de matériel de production	4	2	2	3	1,3
	F3 – Prestataire informatique	3	4	2	2	3



Élaborer des scénarios stratégiques

Exemple : société de biotechnologie





1. Construire la cartographie de menace de l'E/S

Exemple : société de biotechnologie

Quelle est votre interprétation de cette cartographie ? Quelles sont les parties prenantes les plus critiques et pourquoi ?

Partie prenante	Niveau de menace	Points durs
F3 – Prestataire informatique	Très élevé	Exposition très élevée & fiabilité cyber faible
P3 – Laboratoires	Très Elevé	Exposition élevée & fiabilité cyber faible
F1- F2- P1	Elevé	Exposition très élevée & maturité cyber faible